

BEAR

Defensive Control Mapping
Break -> Expand -> Ascend -> Rule

A concise model for shared operational context

BEAR reduces an intrusion to four questions. It is a communication layer, not a replacement for ATT&CK, the Cyber Kill Chain, NIST CSF, ISO/IEC 27001, or CIS Controls. Real intrusions can revisit phases, run phases in parallel, or create impact without completing every phase.

Phase	Operational question	Transition	Representative ATT&CK tactics
BREAK	Did the adversary get in?	Outside -> Inside	Initial Access (TA0001), Execution (TA0002)
EXPAND	How far did the adversary move?	One -> Many	Persistence (TA0003), Discovery (TA0007), Lateral Movement (TA0008), Command and Control (TA0011)
ASCEND	Did the adversary gain privileged control?	User -> Administrator	Privilege Escalation (TA0004), Credential Access (TA0006)
RULE	What impact can the adversary create?	Access -> Impact	Collection (TA0009), Exfiltration (TA0010), Impact (TA0040)

Maintained by Christopher Six (@christophersix66)

Version 2.0 | 2026-09-02 | github.com/christophersix66

BEAR Framework concept credited by the original project to Ivan Novikov (Wallarm).

Mapping method and boundaries

The mappings in this document are practitioner alignments that help a team pivot from a BEAR phase into established security vocabularies. They are not official crosswalks, certification evidence, or claims of one-to-one equivalence.

Reference	Use in BEAR
MITRE ATT&CK v19.2	Tactics and techniques are representative, not exhaustive. ATT&CK objects are many-to-many and can span more than one BEAR phase.
NIST CSF 2.0	The Core expresses outcomes, not products. Product examples are mapped to the closest supported outcome and retain the official two-digit subcategory form.
ISO/IEC 27001:2022	Annex A is a reference set. Applicability is determined through organizational risk assessment, risk treatment, and the Statement of Applicability.
CIS Controls v8.1	Entries point to the closest prescriptive safeguards. Implementation Group scope and organizational applicability still need to be evaluated.
BEAR priority labels	Critical, High, and Medium labels are a starting point for discussion, not a universal risk rating. Tailor them to organizational risk.

Corrections from version 1.1

- Replaced CSF 1.1 categories PR.AC, PR.IP, and PR.PT that had been labeled as CSF 2.0.
- Adopted the current CSF 2.0 categories PR.AA, PR.PS, and PR.IR and official two-digit subcategory identifiers.
- Narrowed CIS mappings to the safeguards actually described, including 7.6 for external scanning, 13.4 for segment filtering, 13.2/13.7 for host detection and prevention, and 12.8 for dedicated administrative resources.
- Updated ATT&CK technique names and tactic membership to Enterprise ATT&CK v19.2.
- Removed claims of strict equivalence and documented the risk-based use of ISO Annex A.

Perspective

The phase questions use neutral incident-response language ('the adversary') so tactical, defensive, and executive audiences can share the same status statement. Red-team operators may restate the questions in first person during an exercise.

BREAK

Outside -> Inside

Did the adversary get in?

Representative ATT&CK tactics	Initial Access (TA0001), Execution (TA0002)
Representative techniques	T1190 Exploit Public-Facing Application; T1133 External Remote Services; T1078 Valid Accounts; T1566 Phishing; T1204 User Execution

Attacker objectives	Detection opportunities	Operational metrics
- Exploit public-facing applications or APIs - Abuse external remote services or valid accounts - Use phishing and user execution to establish a foothold - Reach initial code execution inside the defended environment	- Authentication failure spikes and impossible travel - WAF, IDS, or gateway exploit indicators - Unusual API patterns and newly exposed services - Phishing delivery, link, attachment, and user-execution signals	- External asset inventory coverage - Externally exposed vulnerability remediation time - MFA coverage for exposed, remote, and administrative access - Time from initial-access signal to triage

Defensive control alignment

Defensive capability	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	CIS Controls v8.1
External asset inventory	ID.AM-01/02/03	A.5.9	1.1, 1.3, 1.5, 2.1
External vulnerability scanning and remediation	ID.RA-01; PR.PS-02	A.8.8	7.6, 7.7
MFA for exposed apps, remote access, and administrators	PR.AA-03	A.8.5	6.3, 6.4, 6.5
Edge and application configuration hardening	PR.PS-01	A.8.9	4.1, 4.2
WAF or application-layer gateway filtering	PR.IR-01	A.8.20	13.10
Authentication anomaly monitoring and analysis	DE.CM-03; DE.AE-02	A.8.16	8.11, 13.1
Email and browser attack-surface reduction	PR.PS-01; PR.AT-01	A.6.3; A.8.7; A.8.23	9.1-9.7; 14.2

EXPAND

One -> Many

How far did the adversary move?

Representative ATT&CK tactics	Persistence (TA0003), Discovery (TA0007), Lateral Movement (TA0008), Command and Control (TA0011)
Representative techniques	T1053 Scheduled Task/Job; T1018 Remote System Discovery; T1083 File and Directory Discovery; T1021 Remote Services; T1071 Application Layer Protocol

Attacker objectives	Detection opportunities	Operational metrics
- Discover identities, hosts, data stores, and trust relationships - Move to internal, cloud, SaaS, or orchestration environments - Establish persistence and command-and-control paths - Turn one foothold into multiple reachable options	- SMB, RDP, WinRM, SSH, or cloud lateral movement - LDAP, DNS, service, host, and file-share discovery - New scheduled tasks, services, tokens, or persistence objects - First-time cloud API activity and behavior-baseline deviations	- Segmentation policy coverage and denied-path validation - Endpoint monitoring coverage - Mean time from lateral-movement signal to containment - Behavior-alert investigation yield

Defensive control alignment

Defensive capability	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	CIS Controls v8.1
Network segmentation and east-west filtering	PR . IR -01	A . 8 . 22	12 . 2, 13 . 4
Zero-trust access and least privilege	PR . AA -05; PR . IR -01	A . 5 . 15; A . 5 . 18	6 . 8, 13 . 5
Endpoint detection and response	DE . CM -09	A . 8 . 7; A . 8 . 16	13 . 2, 13 . 7
Network traffic and flow monitoring	DE . CM -01	A . 8 . 16	13 . 3, 13 . 6
Behavior analytics and event correlation	DE . CM -03; DE . AE -02/03	A . 8 . 16	8 . 11; 13 . 1, 13 . 11
Application allowlisting	PR . PS -05	A . 8 . 19	2 . 5, 2 . 6, 2 . 7
Cloud posture, workload, and provider monitoring	PR . PS -01; DE . CM -06/09	A . 5 . 23; A . 8 . 9; A . 8 . 16	4 . 1, 4 . 2, 15 . 6

ASCEND

User -> Administrator

Did the adversary gain privileged control?

Representative ATT&CK tactics	Privilege Escalation (TA0004), Credential Access (TA0006)
Representative techniques	T1068 Exploitation for Privilege Escalation; T1548 Abuse Elevation Control Mechanism; T1003 OS Credential Dumping; T1558 Steal or Forge Kerberos Tickets

Attacker objectives	Detection opportunities	Operational metrics
- Escalate to root, SYSTEM, tenant, domain, or cluster administration - Dump, steal, forge, or replay privileged credentials - Control identity, certificate, CI/CD, or management planes - Convert ordinary access into durable administrative authority	- Privilege escalation, token manipulation, and security-control bypass - Sensitive group, role, policy, certificate, or trust changes - Kerberoasting, DCSync, credential dumping, and abnormal ticket use - First-time or out-of-pattern privileged activity	- Standing privileged identity count - Administrative MFA and dedicated-workstation coverage - Privileged-access review completion - Mean time to detect and revoke unauthorized privilege

Defensive control alignment

Defensive capability	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	CIS Controls v8.1
PAM and dedicated administration	PR.AA-05	A.8.2	5.4, 12.8
Just-in-time elevation and privileged-role governance	PR.AA-05	A.5.18; A.8.2	6.1, 6.2, 6.8
Credential vaulting and local admin password management	PR.AA-01/04	A.5.17; A.8.5	5.2, 6.5
Credential isolation and authentication hardening	PR.AA-04; PR.PS-01	A.8.5; A.8.9	4.1, 4.2, 10.5
Privileged directory and policy change monitoring	DE.CM-03/09	A.8.15; A.8.16	8.5, 8.11
Privileged behavior analytics and alert tuning	DE.AE-02/03	A.8.16	13.1, 13.11

RULE

Access -> Impact

What impact can the adversary create?

Representative ATT&CK tactics	Collection (TA0009), Exfiltration (TA0010), Impact (TA0040)
Representative techniques	T1213 Data from Information Repositories; T1567 Exfiltration Over Web Service; T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery

Attacker objectives	Detection opportunities	Operational metrics
- Collect and exfiltrate sensitive information - Disrupt, alter, encrypt, or destroy systems and data - Block recovery or retain leverage for extortion - Create material operational, legal, financial, or safety impact	- Bulk access, archive creation, staging, and external transfers - DNS tunneling and unusual egress paths - Backup deletion, encryption, or retention-policy changes - Mass file modification, service disruption, or destructive commands	- Sensitive-data inventory and DLP coverage - Exfiltration alert investigation and confirmation rate - Backup isolation and tested-restore success - Recovery time and recovery point performance against objectives

Defensive control alignment

Defensive capability	NIST CSF 2.0	ISO/IEC 27001:2022 Annex A	CIS Controls v8.1
Data inventory and classification	ID.AM-05/07	A.5.9; A.5.12	3.2, 3.7
DLP and egress control	PR.DS-01/02/10	A.8.12; A.8.20	3.13, 13.10
Sensitive-data access logging and analytics	DE.CM-03/09; DE.AE-02	A.8.15; A.8.16	3.14; 8.5, 8.11
Encryption at rest and in transit	PR.DS-01/02	A.8.24	3.10, 3.11
Protected, isolated backups	PR.DS-11	A.8.13	11.2, 11.3, 11.4
Restore testing and recovery integrity	PR.DS-11; RC.RP-03/05	A.8.13; A.5.30	11.5
Incident response execution and containment	ID.IM-04; RS.MA-01; RS.MI-01/02	A.5.24; A.5.25; A.5.26	17.4, 17.7
Incident communications	RS.CO-02/03	A.5.24; A.5.26	17.2, 17.6

Operational use

Use BEAR to establish position and decision urgency, then pivot to the detailed source framework for analysis, detection engineering, risk treatment, control implementation, or recovery planning.

Scenario	Recommended use
Active incident	Identify the highest confirmed phase, evidence supporting it, reachable assets, business impact, and the next containment decision.
Red-team debrief	Show the furthest demonstrated phase and distinguish observed capability from inferred or theoretical impact.
Control validation	Test whether prevention, detection, containment, and recovery capabilities interrupt each phase; record evidence and gaps.
Executive briefing	State what is confirmed, what remains uncertain, what impact is plausible, and which decision or resource is needed.

Minimum incident status record

For each assessment, capture the timestamp, highest confirmed BEAR phase, confidence level, supporting evidence, affected identities and assets, containment status, plausible impact, decision owner, and next update time. Do not treat an unconfirmed capability as demonstrated impact.

Maintenance rule

Review this mapping register when a referenced framework changes. Verify identifiers and titles against primary sources before publishing a new version. Keep the HTML tool, MAPPINGS.md, and PDF version labels synchronized.

Authoritative references

1. MITRE ATT&CK Version History (current v19.2): <https://attack.mitre.org/resources/versions/>
2. MITRE ATT&CK Enterprise Techniques: <https://attack.mitre.org/techniques/enterprise/>
3. NIST Cybersecurity Framework 2.0, NIST CSWP 29: <https://doi.org/10.6028/NIST.CSWP.29>
4. NIST CSF 2.0 Reference Tool: <https://csrc.nist.gov/Projects/cybersecurity-framework/Tools/#/csf/filters>
5. ISO/IEC 27001:2022: <https://www.iso.org/standard/27001>
6. ISO/IEC JTC 1/SC 27 guidance on Annex A:
https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/ISO-IECJTC1-SC27-WG1_N3297_Auditing%20Practices%20Note%20-%20Annex%20A.pdf
7. CIS Controls v8.1 Navigator: <https://www.cisecurity.org/controls/cis-controls-navigator>

Version record

v2.0 - 2026-09-02 - Framework alignment review, mapping corrections, accessibility and offline improvements. Maintained by Christopher Six (@christophersix66).
v1.1 - Original repository PDF - Behavior drift content added.
v1.0 - Original defensive control mapping.

Credits

BEAR Framework concept: Ivan Novikov (Wallarm), as credited by the original project.
Defensive control mapping, interactive tool, and repository maintenance: Christopher Six - github.com/christophersix66